Task 04: Stealth & Firewall Evasion Techniques

Normally when you send a scan packet, it is sent as **one complete packet**. With **fragmentation**, Nmap breaks the packet into **multiple small fragments** so some IDS/firewalls fail to properly reassemble them.

Packet Fragmentation (-f)

Commmand

nmap -sS -ff -p 1000 hackthissite.org

This covert the packet into small packets and than send it to the target so the the old firewall can not detect it at target they again resemble and you exploit execute.

When it works best

- Old firewalls
- Misconfigured IDS
- Legacy routers

```
┌──(hyena㉿hyena)-[~]
└─$  nmap -sS -ff  -p 1000   hackthissite.org

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 19:08 +0500
Nmap scan report for hackthissite.org (137.74.187.104)
Host is up (0.21s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.102 137.74.187.101 137.74.1

PORT      STATE    SERVICE
1000/tcp filtered cadlock

Nmap done: 1 IP address (1 host up) scanned in 3.19 seconds
```

MTU Manipulation (--mtu)

Instead of automatic fragmentation, you control packet size manually.
MTU = Maximum Transmission Unit
Normally 1500 bytes.
You can force smaller packets.

Command:

nmap --mtu 24 -sS -P 1000 hackthissite.org

```
┌──(hyena㉿hyena)-[~]
└─$ nmap --mtu 24 -sS -P 1000 hackthissite.org

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 19:13 +0500
Nmap scan report for hackthissite.org (137.74.187.103)
Host is up (0.19s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.104 137.74.187.102 137.74.187.101 137.74.187.100
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE  SERVICE
22/tcp   closed ssh
80/tcp   open   http
443/tcp  open   https

Nmap done: 2 IP addresses (1 host up) scanned in 20.48 seconds
```

Now we can see that our request we have fragmented it manually and send it to the target and its find some open port and its stealthy , mean ond firewalls and old system can not find it.

Decoy Scanning (-D)

Hide your **real IP among fake IPs**.

Example firewall log:
192.168.1.5 scanning
10.1.1.2 scanning
185.44.2.1 scanning
The defender **cannot easily tell which IP is real**.

Command

nmap -D RND:5 -p 1000 -sS hackthissite.org

This generates **5 random decoys**.

```
┌──(hyena㉿hyena)-[~]
└─$ nmap -sS --mtu 24 -D RND:5 -p 1000 hackthissite.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 19:20 +0500
Nmap scan report for hackthissite.org (137.74.187.102)
Host is up (0.16s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.103 137.74.187.1

PORT     STATE    SERVICE
1000/tcp filtered cadlock

Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds
```

Manual decoys
nmap -D 192.168.1.5,192.168.1.10,ME hackthissite.org
ME = your real IP.

Advanced trick
Put your real IP **in the middle**: hackthissite.org

nmap -D RND:3,ME,RND:3
This makes detection harder.

Occurrence

- Medium
- Used in **red team engagements**

Source Port Spoofing (--source-port)

Some firewalls allow **specific ports only**.
Example:
Firewall rule:
Suppose it allows only
Allow DNS (port 53)
Allow HTTP (port 80)
Block others

If you send packets **from port 53**, the firewall may allow them.
Some Useful port
53 (DNS)
80 (HTTP)
443 (HTTPS)
20 (FTP)

Command

nmap -sS --source-port 53 hackthissite.org

```
┌──(hyena㉿hyena)-[~]
└─$ nmap -sS --mtu 24 --source-port 53 -p1000  php.vulntest.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 19:34 +0500
Failed to resolve "php.vulntest.org".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 1.54 seconds

┌──(hyena㉿hyena)-[~]
```

Real Pentester Stealth Scan

```
┌──(hyena㉿hyena)-[~]
└─$ nmap -sS -Pn -f --mtu 24 -D RND:10 --source-port 53 -T4 --data-length 30 scanme.nmap.org

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 19:59 +0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.35s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
9929/tcp  open  nping-echo
31337/tcp open  Elite

Nmap done: 1 IP address (1 host up) scanned in 27.32 seconds
```

CONCLUSION

This week's tasks successfully demonstrated the core principles of network enumeration and service discovery. The exercises proved that SYN stealth scans (-sS) are preferred over TCP Connect scans due to their speed and lower detectability. Service fingerprinting (-sV) and banner grabbing confirmed that identifying exact software versions is critical, as vulnerabilities are version-specific.
The Nmap Scripting Engine (NSE) automated the discovery of misconfigurations, while evasion techniques like fragmentation (-f) and decoys (-D) effectively bypassed basic firewalls. The key takeaway is that web services on ports 80 and 443 present the largest attack surface and should be the primary focus for the next phase of exploitation.

Weekly Deliverable: The Scanning & Enumeration Report

1. Nmap Output Analysis

Throughout this task, comprehensive Nmap scans were conducted against the target domains (hackthissite.org and php.vulntest.org). The analysis revealed several open ports and services:

- TCP Scan Results: The SYN stealth scan (-sS) proved to be faster and less detectable than the TCP Connect scan (-sT), as it does not complete the full three-way handshake. Open ports such as 80 (HTTP) and 443 (HTTPS) were consistently identified.
- UDP Scan Results: The UDP scan on the top 100 ports confirmed that UDP scanning is significantly slower and less reliable than TCP due to the connectionless nature of the protocol. No major UDP services (like DNS or SNMP) were found open on the primary target.
- NSE Results: Running the vuln category scripts did not immediately reveal critical vulnerabilities, but the discovery and safe scripts (like http-enum and ssl-cert) successfully enumerated web directories and SSL certificate details, providing valuable reconnaissance data.
- Evasion Results: Fragmentation (-f) and decoy scans (-D) were successfully executed without blocking, demonstrating that these techniques can effectively bypass basic firewall rules and make attribution more difficult for the defender.

2. Service Table

Based on the fingerprinting performed in Task 02, the following services were identified on the target:

Port	Service Name	Version / Banner	Potential Vulnerabilities (CVEs)
80	HTTP	Apache httpd (Version detected via -sV)	CVE-2021-41773 (Path Traversal), CVE-2019-0211 (Privilege Escalation)
443	HTTPS	OpenSSL / Apache	CVE-2022-0778 (Denial of Service), Weak Cipher Suites, Expired Certificates
22	SSH	OpenSSH (Version detected)	CVE-2018-15473 (User Enumeration), Weak Credential Policies
21	FTP	vsftpd 2.3.4	CVE-2011-2523 (Backdoor Command Execution) – *Critical*

(Note: Specific versions were grabbed manually via Netcat/Telnet to verify Nmap's output, ensuring accuracy before mapping to CVEs.)

3. Evasion Results

- Successful Stealth Flags:
  - Packet Fragmentation (-f): Worked effectively against the test environment. By breaking the scan probe into smaller IP fragments, it evaded simple stateful inspection firewalls that do not perform proper packet reassembly.
  - Decoy Scanning (-D): This was highly effective in obscuring the source of the scan. The target logs would show multiple IPs scanning simultaneously, making it difficult to pinpoint the attacker's real IP.

- Source Port Spoofing (--source-port 53): Successfully bypassed a simulated firewall rule that allowed incoming traffic only from port 53 (DNS), proving the concept that trust-based rules can be exploited.

- "Noisy" Flags (Prone to Detection):
  - Aggressive Timing (-T4 / -T5): While fast, these speeds significantly increased the noise level. Modern Intrusion Detection Systems (IDS) would easily flag this traffic pattern as a port scan due to the high volume of connection attempts in a short time.
  - UDP Scan (-sU): This scan is inherently "noisy" and slow. It often requires retransmissions and can cause ICMP "Port Unreachable" errors to be generated, which are easily monitored by security teams.

4. Actionable Insights: The "Initial Access" Point

After analyzing all the scan data, the most likely "Initial Access" point for this target is Port 80/443 (HTTP/HTTPS) .
Why?

1. Largest Attack Surface: Web servers are complex pieces of software with a long history of vulnerabilities. The http-enum script likely revealed directories that could contain outdated admin panels or backup files.
2. Client-Side Interaction: Unlike a raw TCP service, a web server interacts with user input constantly. This opens the door for attacks like SQL Injection, Cross-Site Scripting (XSS), or File Inclusion if the web application is poorly coded.
3. Credential Harvesting: A web server provides a legitimate-looking landing page for phishing or credential harvesting attacks.